SECURITY INCIDENT INVESTIGATION REPORT

INTERNAL — INVESTIGATION

Organisation	Report date	Classification
Northgate Retail Ltd	6.9.2026	critical

Investigation team

Role	Name	Sections owned
Case Lead	Elay	1, 2, 4, 10
Identity & Access	Yossef	3, 5a
Data & Impact	Gavriel	5b, 7
Intel & Context	Elay	8, 9

1 · Executive Summary

Starting August 9, an outside party gained unauthorized access to our supplier web portal and pulled inventory data for all 38 branches. Over the following two weeks, they moved deeper into our internal network using administrator-level access, reached the system that manages our payment registers, pushed changes to 34 individual registers, and wrote into log records to cover their tracks. On August 19, they sent roughly 180 MB of data outside the company - the largest such transfer seen in three months - then deleted their access tools and erased over 2,500 files, likely to hide further evidence.

The incident is not fully contained. While the attacker removed some of their cleanup tools, automated data harvesting remained active after the initial deletion phase. The initial entry path through the supplier portal is currently being remediated to block further unauthorized access.

To fully contain the breach and protect operations, we urgently require executive authorization to isolate all affected payment registers, deploy EDR across the POS machines, enforce a reset of all administrative credentials, and start a specialized forensic audit of transaction log contents to detect potential cardholder exposure.

2 · Incident Classification & Severity

Category: Data exfiltration, Severity: Critical
Justification & Reasoning:

- Asset Criticality & Operational Scope:
    - Compromised Critical Assets: The attacker obtained administrative/special privileges on key organizational servers (SRV-FILE-HQ, SRV-POSMGT, SRV-VEND-APP), with SRV-POSMGT classified as a highest-priority (Critical) asset. Additionally we have high confidence the attacker took over the admin user a.mizrahi which led him to take control of user r.stern.
    - Scope of Endpoints: The attacker deployed configuration modifications (ngpos-cfg.exe) and executed automated data collection across 34 out of 42 Point-of-Sale (POS) branch terminals. All affected POS terminals are designated as High-criticality assets lacking EDR agents.
- Confirmed Impact:
    - Verified Data Exfiltration: On August 19, 2026, between 02:55:01 and 04:10:01 UTC, the attacker successfully exfiltrated 180.0 MB of data from SRV-STAGE-01 to an external server (edge-sync-eu.net) across 6 HTTP POST requests with allow verdict by the proxy.
    - Disruption: The attacker actively deleted scheduled tasks (schtasks /delete), erased 2,510 POS log files, and took deliberate steps to cover their tracks.
    - Confirmed Business Impact: Notifications were received from the merchant acquiring bank regarding credit card fraud linked to transactions conducted at retail branches within the incident timeframe.
- Potential Impact:
    - Payment Card Data Exposure (PCI-DSS): The exfiltrated archives contained transaction log files (.log.1). The type of data within the logs could not be verified due to missing information ,but the log file types combined with the merchant bank's fraud alerts present a high risk of cardholder data compromise.
    - Active & Ongoing Exposure: The incident remains a live operational threat. Automated data collection continued for roughly 17 hours after the initial log deletion attempts, with data capture truncating on August 20 mid-day while malicious activity was still active. Furthermore, the initial web application entry vector had not yet been remediated.

3 · Entities

Entity	Type	Role in the incident	Confidence
77.124.66.19	IP Address	Breached from the web And enumerated all the possible POS branches	Confirmed
77.124.66.31	IP Address	None	Ruled out
POS-(B1-B34)-01	POS	All these POS branches were used by the attack to get the sensitive information	Confirmed
SRV-VEND-APP	Server	This server was used to implement a scheduled task to understand the network and for lateral movement	Confirmed
SRV-POSMGT	Server	This server hosts all the POS branches, and was used to access them	Confirmed
SRV-STAGE-01	Server	This server was used to upload and archive all the file collected by the POS branches	Confirmed
SRV-CARDPROC	Server	None	Ruled Out
SRV-DC-01	Server	None	Ruled out
SRV-FILE-HQ	Server	A.mizrahi used this server for reconnaissance (objective still unknown)	Confirmed
R.stern	Standard User	The main user used to access SRV-POSMGT and carry most the attack	Confirmed
E.katz	Standard User	None	Ruled Out
y.oren	Standard User	None	Ruled out
a.mizrahi	Admin User	Mizrahi is the only Admin account, the attacker used his privileges to carry the attack	Confirmed
WEB-SUPPLIER	Web server	The attacker used a breach in the web server to gain access to web shell and start the attack	Confirmed

4 · Timeline

Time (UTC)	Source	Host / Actor	What happened	Evidence ref
2026-08-09 07:12:00	weblog	WEB-SUPPLIER/ 77.124.66.19	Successful POST /supplier/login. Account cannot be identified — weblog has no user field	Appendix B #1
2026-08-09 07:40:01 → 07:47:54	weblog	WEB-SUPPLIER / 77.124.66.19	44 API requests enumerating branches B01–B38 at fixed 11.0s intervals, all HTTP 200. /supplier/api/v2/inventory?branch=B<number>	Appendix B #1
2026-08-10 23:04:01 (Translated UTC+3)	winevent 4688	SRV-VEND-APP / IIS APPPOOL\supplier	w3wp.exe spawns cmd.exe running whoami & ipconfig /all & net view	Appendix B #2
2026-08-10 23:31:01 (Translated UTC+3)	winevent 4698	SRV-VEND-APP/ IIS APPPOOL\supplier	scheduled task named 'NGSupplierSync' configured to execute every 4 hours without specifying what program to run. Raw command schtasks /create /tn NGSupplierSync /sc hourly /mo 4	Appendix B #2
2026-08-11 2:15:01 (Translated UTC+3)	winevent 4624+4672	SRV-FILE-HQ / a.mizrahi from SRV-VEND-APP	a.mizrahi logon (Type 3) to SRV-FILE-HQ from SRV-VEND-APP with special privileges (4672).	Appendix B #3
2026-08-12 22:00:00 → 08-15 22:46:12 (Translated UTC+3)	winevent 5140	SRV-FILE-HQ / a.mizrahi from SRV-VEND-APP	40 events with 6 distinct shared folder paths. No files touched.	Appendix b #12, Appendix b #13

2026-08-15 21:46:59 (Translated UTC+3)	winevent 4624	SRV-POSMGT / r.stern from SRV-VEND-APP	r.stern logon (Type 3) to SRV-POSMGT from SRV-VEND-APP. First time Logon in 90 days. Base: logon from SRV-POSMGT SRV-CARDPROC WKS-PAY-02	Appendix B #5
2026-08-16 01:19:59 → 01:29:20 (Translated UTC+3)	winevent 4688	34 × POS / r.stern	Automated distribution of a configuration file across 34 POS machines at fixed 17-second intervals. Raw command: ngpos-cfg.exe /apply /src \\SRV-POSMGT\cfg\pos-profile.dat	Appendix B #7
2026-08-16 03:00:00	fileaudit	SRV-STAGE-01 / r.stern	Collection begins on \\SRV-STAGE-01\temp	Appendix B #8
2026-08-16 → 2026-08-19, daily 03:00:00–22:34:19	fileaudit	SRV-STAGE-01 / r.stern from POS-B<POS-number>-01 x 34	Every POS machine writes between 84-83 distinct files with *.log.1 format, 712.5 files per day, 430 MB in total	Appendix B #8
2026-08-18 00:10:01 (Translated UTC+3)	winevent 4688	SRV-STAGE-01 / r.stern	archive created from 1425 files (214.93 MB) Raw command: ngarch.exe -a -q -o D:\temp\ngsync-0819.dat \\SRV-STAGE-01\temp*.log.1	Appendix B #7, Appendix B #6
2026-08-19 02:55:01 → 04:10:01	proxy	SRV-STAGE-01/unknown	6 POSTs to edge-sync-eu.net, 180 MB in total, 15 min apart, all allowed.	Appendix B #9

2026-08-19 04:30:00 (Translated UTC+3)	winevent 4698	SRV-VEND-APP/IIS APPPOOL\supplier	Deletion of scheduled task 'NGSupplierSync ' Raw command: schtasks /delete /tn NGSupplierSync /f	Appendix B #2
2026-08-19 04:30:00 → 05:07:38	fileaudit	SRV-STAGE-01 / r.stern	2,510 files destroyed in 37m 38s. 22 files written during the window — collection never paused	Appendix B #10, Appendix B #11
2026-08-19 22:34:19	fileaudit	SRV-STAGE-01 / r.stern	Last staged write. 340 files never deleted, 53,820,040 bytes, all 34 terminals	Appendix B #14

5 · Investigation — What We Checked

5a · Identity & Access

Question	Query / method	Result
Is e.katz's 1116 Event ID malicious?	index=northgate sourcetype=winevent EventCode="1116"	We see the alert fired because of a windows defender trigger, and none malicious
How did the attacker get initial access?	index=northgate sourcetype=winevent | where extracted_host="SRV-VEND-APP"	3 logs containing the initial access and more
What are all the actions done with the malicious files (ngpos-cfg.exe,ngarch.exe) by r.stern With shown difference of time between logs	index=northgate sourcetype=winevent EventCode=4688 actor="r.stern" process="ngpos-cfg.exe" OR process="ngarch.exe" | streamstats window=1 current=f last(_time) as prev_time | eval delta_seconds = prev_time - _time | eval time_diff = tostring(abs(delta_seconds), "duration") | table _time, extracted_host, process, cmdline,time_diff | sort _time	Found that ngpos-cfg.exe ran on 34/42 POS's terminals with defined intervals of 17 seconds, and after 2 days 22 hours ngarch.exe was used to collect all the data.
What are all the process creating event id 4698 that occurred	index=northgate sourcetype=winevent EventCode=4698	We only see the 2 we already knew about - creation of scheduled task and deletion after the POST requests through the proxy.
Did the attacker get access using kerberoasting?	index=northgate sourcetype=winevent EventCode=4769 OR EventCode=4768 earliest="08/01/2026:00:00:00" latest="08/20/2026:00:00:00" | streamstats window=1 current=f last(_time) as prev_time | eval delta_seconds = prev_time - _time | eval time_diff = tostring(abs(delta_seconds), "duration") |table _time, actor, EventCode, time_diff	After checking all the logs we didn't see any fixed intervals, I also checked a.mizrahi and r.stern alone. Nothing found, searched at different times as well.

How did the attacker know how many POS machines there are?	index=northgate 77.124.66.19	We knew 77.124.66.19 is malicious so we filtered on that and saw the reconnaissance on all the POS's
How many process creations did r.stern do?	index=northgate sourcetype=winevent EventCode=4688 |where actor="r.stern"	I found all the processes stern did and in there we saw the POS modifications and data gathering
Is y.oren a part of the attack?	index=northgate actor="y.oren" action="create"	We found that he created files which he is not supposed to, but after further investigation we found that he created files regarding his line of work
How many POS machines are available in the logs?	|inputlookup assets.csv	There we can see all the assets and we can see 38 different machines and 4 duplicates giving a total of 42
Has anyone else used the malicious exe files?	index=northgate ngpos-cfg.exe AND index=northgate ngpos-cfg.exe r.stern	I searched the whole log base for the exe file and found 34 events, and then i filtered by r.stern and saw 34 again, meaning no one else used those files
Had a.mizrahi used any abnormal exe files?	index=northgate sourcetype=winevent a.mizrahi EventCode=4688 |table _time, process	I found only legit processes such as outlook winword chrome excel etc

5b · Data & Impact

Question	Query / method	Result
Which accounts move abnormal file volume?	index=northgate sourcetype=fileaudit | stats count sum(bytes_out) by actor	FINDING — r.stern: 5,457 events, 466,845,388 bytes. 40× the ~110-event user baseline. Only svc_pricefeed is higher and is the sanctioned nightly price push.
Does any server show single-actor use?	index=northgate sourcetype=fileaudit | stats count dc(actor) values(actor) by server	FINDING — SRV-STAGE-01: 5,360 events, exactly one actor across 90 days. SRV-FILE-HQ by contrast is used by 29 accounts.
Was that server in use before the incident?	index=northgate server=SRV-STAGE-01 latest="08/16/2026:00:00:00" | stats count	NULL RESULT — zero events in the preceding 85 days. The first file activity on the host is the start of the harvest.

What was staged, how much, from where, and when?	index=northgate server=SRV-STAGE-01 action=write | stats count sum(bytes_out) dc(src_host) min(_time) max(_time)	FINDING — 2,850 files, 450,879,900 bytes (430.0 MiB), 34 terminals, 2026-08-16 03:00:00 → 2026-08-19 22:34:19.
Was the collection manual or automated?	index=northgate server=SRV-STAGE-01 action=write | bin _time span=1d | stats count min(_time) max(_time) by _time	FINDING — 713/712/713/712 files per day, start and end identical to the second daily (03:00:00 → 22:34:19), ~101-second cadence, two parallel write streams. Automated.
Was evidence destroyed, and completely?	index=northgate action=delete | stats count min(_time) max(_time); write-minus-delete comparison by object_path	PARTIAL — 2,510 files destroyed in 37m38s on 19/08. 340 files (53,820,040 bytes) were never deleted, spanning all 34 terminals.
Did collection stop during the cleanup?	index=northgate action=write earliest="08/19/2026:04:30:00" latest="08/19/2026:05:07:38"	NEGATIVE — no. 22 files were written during the deletion window; the two processes ran concurrently.
Did the activity stop at all?	index=northgate action=write earliest="08/19/2026:05:07:39"	NEGATIVE — no. 624 further files to 22:34:19. Data ends 20/08 11:56 with the operation still active.
What did the compromised account read?	index=northgate actor=r.stern action=read | stats count sum(bytes_out) by server	NULL RESULT — zero reads on the staging server; all 5,360 events there are writes and deletes. The account's only reads are 80 Payments documents on \\SRV-FILE-HQ\Payments from its own workstation, spread across 90 days.
Did the source terminals have endpoint detection?	index=northgate action=write | stats count by src_host | lookup assets.csv hostname as src_host OUTPUT has_edr criticality	NULL RESULT — none. All 34 are has_edr=no, criticality=high, segment pos-branch. No process telemetry exists from any branch terminal.
Were all POS terminals affected?	index=northgate | inputlookup assets.csv | search hostname=POS-* compared against observed src_host	PARTIAL — 34 of 42. Four were enumerated then skipped despite logging normally; four emit no events at all. 34 is a floor, not a total.

Was the cloud platform the exfiltration channel?	index=northgate sourcetype=cloudaudit actor=r.stern | stats count by operation; operation=share_link_create | stats count by link_scope	NULL RESULT — no. 37 events spread evenly across 90 days with no clustering on 16–19/08. All 63 share links are internal scope; zero external.
Were backups deleted, failed or tampered with?	index=northgate sourcetype=backup | stats count by status; weekly archive size trend	NULL RESULT — no. 103 of 103 jobs SUCCESS. Weekly card-processing archive ran all 13 weeks at 1,906–2,265 GB with no anomalous drop.
Is backup coverage adequate?	index=northgate sourcetype=backup | stats count by target	GAP — all 103 jobs target SRV-FILE-HQ alone. All three critical servers are unprotected, as are SRV-STAGE-01 and all 42 terminals.
Was the cardholder environment accessed?	index=northgate sourcetype=winevent EventCode=5140 object_name="*CARDPROC*" | stats count by actor src_host	NULL RESULT — no. All 74 connections to \\SRV-CARDPROC\Payments originate from four Payments workstations operated by their assigned users. None from SRV-VEND-APP or SRV-STAGE-01.
Were the POS price files tampered with?	index=northgate object_path="*\\prices*" | stats count by actor action	NULL RESULT — no. All 27,360 events are svc_pricefeed writes, uniform at 40,000–46,300 bytes, continuing normally through 20/08.
Was anything taken from the file server?	index=northgate sourcetype=fileaudit src_host=SRV-VEND-APP | stats count	NULL RESULT — no. During the four-night share enumeration, r.stern has zero file events on SRV-FILE-HQ and a.mizrahi has four, from their own workstation.
Was m.saban, the registered owner of the staging server, involved?	index=northgate actor=m.saban | stats count by server; winevent | stats count by src_host	RULED OUT — all 126 file events are on \\SRV-FILE-HQ\IT from WKS-IT-09; zero events on the server they own. All 522 winevent events originate from that same workstation.

Did the staged data leave the network?	index=northgate sourcetype=proxy src_host=SRV-STAGE-01 (cross-source, Intel & Context)	FINDING — yes. Six POSTs to edge-sync-eu.net, 188,743,680 bytes (180.0 MiB), 19/08 02:55:01–04:10:01, all permitted. The only six proxy events that host generates in 90 days.
Was the account's earlier file activity malicious?	index=northgate actor=r.stern server=SRV-FILE-HQ | stats count min(_time) max(_time) by action	COULD NOT DETERMINE — 97 events on \\SRV-FILE-HQ\Payments from the account's own workstation, matching its department and function, at 08:00–16:00 local. Not separable from legitimate work.

5c · Intel & Context

Question	Query / method	Result
Who sends the most bytes out through the proxy?	`index="northgate" sourcetype="proxy" |table time, method, bytes_out, verdict, dest_host |sort -bytes_out`	SRV-STAGE-01 is take the six most bytes out requests to the proxy, all allowed
Did SRV-STAGE-01 speak to the proxy at other times as well?	`index="northgate" sourcetype="proxy" src_host="SRV-STAGE-01" method != "POST"`	No logs found
What other hosts talked with edge-sync-eu.net?	`index="northgate" sourcetype="proxy" dest_host="edge-sync-eu.net" | stats dc(src_host) values(src_host)`	Only SRV-STAGE-01 sends packets to edge-sync-eu.ne.

What are the distinct user agents in the proxy? Are there any suspicious ones?	index=northgate sourcetype=proxy | stats count by user_agent | eval is_suspicious=case(isnull(user_agent) OR user_agent="" OR user_agent="-", "Suspicious: Missing User-Agent", len(user_agent) < 10, "Suspicious: Extremely short User-Agent", match(user_agent, "(?i)(curl|wget|python|powershell|cmd|nikto|sqlmap|nmap|go-http-client|java)"), "Suspicious: Automated/CLI tool", true(), "Legitimate / Standard") | stats count(user_agent) as total_distinct_user_agents, values(user_agent) as user_agent_list, values(is_suspicious) as analysis_status	There is no suspicious user agent

Are there users that their average volume of bytes out up to two weeks ago is at least half the average volume of bytes out over the last two weeks?	index="northgate" sourcetype="proxy" earliest="05/23/2026:11:08:27" latest="08/06/2026:23:59:59" |bucket time span=1d |stats sum(bytes_out) as bytes_per_day by src_host, time |stats avg(bytes_per_day) as daily_avg_before_incident by src_host |join type=left src_host [search index="northgate" sourcetype="proxy" earliest="08/07/2026:00:00:00" latest="08/20/2026:11:48:58" |bucket time span=1d |stats sum(bytes_out) as bytes_per_day by src_host, time |stats avg(bytes_per_day) as daily_avg_in_incident by src_host] |where daily_avg_in_incident >= (daily_avg_before_incident*2)	WKS-HQ-13, WKS-HQ-20, WKS-IT-08 exhibited a significant anomaly by doubling their average daily outbound data traffic during the incident window compared to their baseline. After further investigation I concluded that this anomaly is not strong indicator for malicious activity.
What outbound proxy access was not approved for several unique machines?	index="northgate" sourcetype="proxy" verdict!="allowed" | stats dc(src_host), values(src_host)	30 machines found, no anomaly found

What IP addresses make the most requests to the WEB-SUPPLIER?	index="northgate" sourcetype=weblog | stats count as total_requests, sum(bytes_out) as total_bytes_sent, dc(host) as unique_hosts_visited, dc(uri_path) as unique_paths_requested by src_ip | eval total_MB = round(total_bytes_sent/1024/1024, 2) | table src_ip, total_requests, total_MB, unique_hosts_visited, unique_paths_requested | sort - total_requests	77.124.66.31 made 91 requests and 77.124.66.19 made 48 requests while all the others made between 2-1 requests.
Which distinct paths those suspicious addresses accessed on the company's public website?	index=northgate sourcetype=weblog |where src_ip="77.124.66.31" or src_ip="77.124.66.19" | stats count(uri_path) as total_count, dc(uri_path) as unique_uri_count, values(uri_path) as requested_paths, sum(bytes_out) as total_bytes by src_ip | table src_ip, total_count, unique_uri_count, requested_paths	77.124.66.19 enumerate /supplier/api/v2/inventory branches - IDOR enumeration 77.124.66.31 access to 6 unique paths - no malicious activity was found.

6 · What Could Not Be Determined

Item	Reason	What this means for the reader
Obtaining a webshell on SRV-VEND-APP via the API enumeration.	No data source	Cannot rely on: Assuming the API enumeration directly led to the webshell vulnerability on SRV-VEND-APP. Needed to close: Web application access logs, WAF telemetry, or code audit for SRV-VEND-APP.
What was inside the POST requests that send to edge-sync-eu.net	No access	Cannot rely on: Confirming that the exfiltrated data matches the archived files staged in \SRV-STAGE-01\temp. Needed to close: PCAP files, proxy payload inspection for outbound traffic to edge-sync-eu.net.
The Identity behind POST requests to edge-sync-eu.net	No data source	Cannot rely on: Attributing outbound C2 traffic to a specific user or service account since proxy logs lack actor details. Needed to close: Endpoint EDR telemetry
Initial credential theft method for r.stern and a.mizrahi	No access	Cannot rely on: Determining the exact technique (e.g., LSASS dumping, phishing) used to compromise these accounts. Needed to close: Memory forensic dumps from compromised hosts.
Actions performed by ngpos-cfg.exe on POS terminals and staging content sent to \SRV-STAGE-01\temp	No data source	Cannot rely on: Knowing the exact nature of harvested data (whether credit card Track data, configs, or system logs). Needed to close: Deploying EDR on POS endpoints and performing forensic investigation on ngpos-cfg.exe and ngsync-0819.dat

Exact execution details of scheduled task NGSupplierSync	No data source	Cannot rely on: Verifying the specific payload or commands executed by NGSupplierSync, the flag /tn not specifying the program that need to run. Needed to close: Task Cache Registry & Process Tree Analysis: Inspect the Registry key at: **HKLM\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Schedule\TaskCache\Tasks** to extract the defined action/payload, and reconstruct the process tree by tracing parent-child relationships
Confirmation of HTTP request receipt at edge-sync-eu.net	Outside our authority	Cannot rely on: Verifying if the remote C2 server successfully received and stored the transferred data. Needed to close: Seizure/analysis of the external infrastructure by law enforcement or external ISP logs.
Full containment verification of attacker foothold in internal network	Insufficient time	Cannot rely on: Assuming the adversary has been completely evicted or that no secondary backdoors remain. Needed to close: Forensic disk analysis of SRV-VEND-APP, reverse engineering of pos-profile.dat, and an enterprise-wide Active Directory compromise assessment.

7 · Impact Assessment

The incident affected the branch point-of-sale estate and resulted in confirmed data egress. The cardholder data environment itself was not reached. Whether payment card data was present in the material taken cannot be determined from the supplied logs, and that distinction governs everything below.

Scope

- Hosts:
  - 34 of Northgate's 42 branch POS terminals, all rated high criticality, none carrying endpoint detection.
  - SRV-STAGE-01- the staging server used to aggregate and export the harvest.
  - SRV-VEND-APP and the critical-rated SRV-POSMGT - used as access points.
- Accounts:
  - a.mizrahi (IT-Infra administrator) and r.stern (Payments) - credentials used without authorisation, exclusively from SRV-VEND-APP and never from their owners' own workstations.
  - IIS APPPOOL\supplier- the web application service identity, the attacker's foothold.
- Data:
  - 2,850 point-of-sale transaction log files, 450,879,900 bytes (430.0 MiB), collected 2026-08-16 03:00:00 → 2026-08-19 22:34:19 UTC.

CONFIRMED Impact

- Data left the estate:
  - On 19 August between 02:55:01 and 04:10:01 UTC, 188,743,680 bytes (180.0 MiB) were transmitted from SRV-STAGE-01 to the external host edge-sync-eu.net across six HTTP POST requests. Every request was permitted by the proxy.
- Collection and destruction:
  - The material was assembled over four days from 34 branch terminals. Twenty minutes after the final upload, the attacker deleted 2,510 of the staged files. 340 files, 53,820,040 bytes, survived.
- What was demonstrably NOT affected:
  - The cardholder data environment was never reached. All 74 connections to \\SRV-CARDPROC\Payments across 90 days originate from four Payments workstations operated by their assigned users. The share was never even enumerated, despite the attacker holding administrator credentials.
  - Nothing was taken from the corporate file server. Four nights of share enumeration produced zero file opens.
  - Backup integrity is sound. 103 of 103 jobs successful, no evidence of tampering.

POTENTIAL Impact

- Presence of cardholder data - unresolved:

    - The file naming (ngpos-*.log.1) and the source hosts identify these as rotated POS transaction logs, which makes card data plausible. No source in the supplied set records file contents. The assessment rests on provenance, not observation.
    - The acquirer's report of fraud on cards used in Northgate branches matches this incident in timing and scope. The logs alone do not prove the connection.
- Volume discrepancy:
    - 180.0 MiB was transmitted against 430.0 MiB staged. An archiving operation on 19 August at 00:10:01 accounts for the gap at a 56% compression ratio, normal for text logs, but a transfer through an unlogged channel cannot be excluded.
- Scope is a floor, not a total:
    - Four terminals emit no telemetry whatsoever, so 34 affected terminals is the minimum, not the maximum.
    - SRV-CARDPROC has no file-level auditing. We observe connections to it but not what was opened inside legitimate sessions.

Business Impact

- Card fraud and notification exposure:
    - Fraudulent transactions have already been reported by the card processor against cards used in Northgate branches during the affected window. Should cardholder data be confirmed in the exfiltrated material, breach-notification duties and card-scheme consequences follow,a determination requiring evidence this dataset does not contain.
- Loss of recovery capability (independent of the intrusion):
    - All 103 backup jobs target SRV-FILE-HQ alone. All three critical servers ,SRV-CARDPROC, SRV-DC-01, SRV-POSMGT -have no recovery capability, nor does the branch estate.
    - Northgate cannot currently restore its card processing, domain, or point-of-sale management infrastructure from backup.

Current Exposure

- The operation was still running when logging ended:
    - No event in any of the seven sources shows the activity stopping. Collection continued for seventeen hours after the cleanup and was never interrupted by it. The final staged file was written at 2026-08-19 22:34:19; logging ends the following midday with the operation active.
- Surviving evidence exists in one location only:
    - 340 files spanning all 34 affected terminals remain on the live disk of SRV-STAGE-01, alongside the archive D:\temp\ngsync-0819.dat. That host is covered by no backup job - this material cannot be recovered once lost, and it is the sole remaining route to establishing whether cardholder data was in scope.
    - Forensic imaging of SRV-STAGE-01 must precede any remediation, rebuild or restart of that host.
- Access cannot be confirmed closed:

- The attacker removed their persistence mechanism on 19 August, but the initial access vector remains unidentified - no web server log exists for SRV-VEND-APP. We cannot state that access has been closed.

Assessment & Confidence Level

Confidence Level: High - for the confirmed impact. Egress volume, timing, destination and the surviving file count are each established by a single unambiguous log source and were independently re-derived.

Confidence Level: Medium - for the link between the exfiltrated material and the acquirer's fraud report. Timing and scope align closely, but the absence of content logging means the connection is inferential.

Confidence Level: Not assessable - for the presence of cardholder data in the exfiltrated files. This is not a matter of insufficient analysis but of absent telemetry, and it will remain unresolved until SRV-STAGE-01 is imaged.

8 · MITRE ATT&CK Mapping & Detection Gaps

Stage	Tactic	Technique	Detected ?	By what
POST /supplier/login	Initial Access (TA0001)	• Valid accounts	yes	weblog
44 API requests enumeration on /inventory	Reconnaissance (TA0043)	• Active Scanning • Wordlist Scanning	yes	weblog
w3wp.exe spawns cmd.exe and run whoami & ipconfig /all & net view	Discovery(TA0003) Execution (TA0002)	• Windows Command Shell • Command and Scripting Interpreter • System Owner/User Discovery • System Network Configuration Discovery • Network Share Discovery/ Network Service Discovery	yes	winevent
Scheduled task creation	Persistence (TA0003) / Privilege Escalation (TA0004)	• Scheduled Task/Job: Scheduled Task	yes	winevent
Account takeover of a.mizrahi in SRV-VEND-APP - Admin credentials used from the compromised host	Privilege Escalation (TA0004) Or Lateral Movement (TA0008) Or Credential Access (TA0006)	• Valid Accounts: Domain Accounts • Use Alternate Authentication Material • OS Credential Dumping	no	winevent
a.mizrahi Logon type 3 from compromise asset (SRV-VEND-APP)	Lateral Movement (TA0008) Defense Evasion(TA0005)	• Remote Services Valid Accounts • Valid Accounts: Domain Accounts	yes	winevent
Automated Network Share Enumeration (SMB Event 5140)	Discovery (TA0007) Collection (TA0009)	• Network Share Discovery • Data from Network Shared Drive	yes	fileaudit
Account takeover of r.stern in SRV-VEND-APP	Privilege Escalation (TA0004) Or Lateral Movement (TA0008) Or Credential Access (TA0006)	• Valid Accounts: Domain Accounts • Use Alternate Authentication Material • OS Credential Dumping		

r.stern Logon type 3 from compromise asset (SRV-VEND-APP)	Lateral Movement (TA0008)	• Remote Service:SMB/Windows Admin Shares • Valid Accounts: Domain accounts	yes	winevent
Automated POS profile configuration deployment via ngpos-cfg.exe	Execution (TA0002) Defense Evasion (TA0005)	• System Service Command and Scripting Interpreter:Service Execution • Abuse Elevation Control Mechanism	yes	winevent
Data collection on \SRV-STAGE-01\temp with .log.1 file format	Collection (TA0009)	• Archive Collected Data / Data Staged:Local Data Staging	yes	fileaudit
Archive *log.1 files into ngsync-0819.dat	Collection (TA0009) / Defense Evasion (TA0005)	• Archive Collected Data: Archive via Utility	yes	winevent
6 POSTs to edge-sync-eu.net	Exfiltration (TA0010) Command and Control (TA0011)	• Exfiltration Over C2 Channel:Exfiltration Over Web Application • Scheduled Transfer • Application Layer Protocol: Web Protocols	yes	proxy
Deletion of Scheduled task	Defense Evasion (TA0005)	• Indicator Removal: Clear Command History or Scheduled Tasks	yes	winevent
Deletion large amount of *.log.1 files on \SRV-STAGE-01\temp	Defense Evasion (TA0005)	• Indicator Removal: File Deletion	yes	fileaudit

9 · What This Resembles

The overall attack chain observed in this incident closely matches the TTPs of financial cybercrime groups specializing in Point-of-Sale (POS) compromises and retail supply-chain intrusions, most notably FIN6 and FIN7.

What Fits:

- Initial Access & Supply Chain Targeting:
    - The attacker came in through the supplier portal (POST /supplier/login) and dropped a Web Shell via IIS (w3wp.exe running cmd.exe). This matches how groups like FIN6/FIN7 target third-party vendors or public web servers to get inside an enterprise network.
- Automated Reconnaissance & Evasion:
    - The attacker used scripted, fixed-interval requests (every 11s for API branches, every 396s for SMB shares) to scan the network. This is a common tactic to map out internal assets while trying to stay under the radar of volume-based alerts.
- POS Terminal Targeting & Software Deployment:
    - Using ngpos-cfg.exe to push pos-profile.dat across 34 terminals at exact 17-second intervals is a classic "Living-off-the-Land" technique. Attackers frequently abuse internal management tools to push malicious configurations or code to POS devices.
- Staging, Masquerading, and Log Harvesting:
    - Gathering 2,138 .log.1 files into a single .dat archive (ngsync-0819.dat) and sending them out via HTTP POSTs matches standard POS staging and exfiltration patterns.

What Does NOT Fit

- Non-use tools for harvesting information from memory:

  Traditional POS attacks rely on dedicated memory scraping malware injected directly into POS processes. In this incident, the attacker modified system settings via pos-profile.dat using the native management binary (ngpos-cfg.exe).

- Stealing Logs Instead of Live Memory Dumps:

  Rather than dumping process memory live to disk, the attacker collected application log files (*.log.1) from SRV-STAGE-01. This implies the configuration change caused the POS software to write cleartext credit card data directly into log files.

Assessment & Confidence Level

Confidence Level: High

The entire attack lifecycle—from supply-chain web access and Living-off-the-Land execution to POS-focused targeting, automated staging, and subsequent cleanup (scheduled task and file deletions)—strongly indicates a financially motivated threat actor executing a targeted POS Payment Card Harvesting Campaign.

10 · Recommendations

Immediate — within 24 hours

#	Recommendation	Ties to finding	Authority
1	Block IP/Domain on proxy and perimeter firewall for edge-sync-eu.net.	6 HTTP POST requests exfiltrating 180 MB to edge-sync-eu.net.	Requires approval
2	Threat intelligence Enrichment about edge-sync-eu.net	C2 exfiltration via 6 HTTP POST requests.	Tier 1
3	Revoke credentials and force password reset for users a.mizrahi and r.stern. Terminate active SMB and network sessions	Lateral movement from compromised assets.	Requires approval
4	Isolate SRV-VEND-APP and remove any persisting Web Shell files/processes spawning from w3wp.exe.	Web shell foothold on IIS server (w3wp.exe spawning cmd.exe).	Requires approval
5	Audit and revert any modified POS profile files (pos-profile.dat) across all 34 terminals.	Unauthorized POS profile deployment via ngpos-cfg.exe.	Management / Legal

Short term — within 30 days

#	Recommendation	Ties to finding	Authority
1	Escalate to Tier 2 to deploy new SIEM detection rules for Event ID 4698 (Scheduled Task creation) and Event ID 5140 (SMB share enumeration).	Unmonitored creation of NGSupplierSync scheduled task and SMB share access across 6 shares.	Tier 1
2	Recommend implementing authentication logging and user ID mapping on /supplier/login.	Successful POST to /supplier/login lacked user field logging in web logs.	Tier 1
3	Recommend applying API rate-limiting and authorization checks on /supplier/api/v2/inventory.	Sequential enumeration of 38 branch codes (B01–B38) at fixed 11-second intervals.	Tier 1
4	Recommend restricting execution of administrative tools ngpos-cfg.exe and ngarch.exe via AppLocker/WDAC policy.	Abuse of ngpos-cfg.exe and ngarch.exe for profile updates and log archiving (322.5 MiB).	Tier 1

Long term

#	Recommendation	Ties to finding	Authority

1	Redesign POS application architecture to eliminate plain-text cardholder data storage in *.log.1 log files.	Harvesting of 2,138 *.log.1 files from \SRV-STAGE-01\temp.	Management / Legal
2	Restrict direct SMB/RPC traffic between SRV-VEND-APP, POS management servers, and POS terminals by enforcing network micro-segmentation.	Direct lateral movement from SRV-VEND-APP to SRV-FILE-HQ, SRV-POSMGT, and SRV-STAGE-01.	Management / Legal
3	Implement MFA and source IP whitelisting for all external supplier access portals.	Initial access gained via external IP 77.124.66.19 accessing the supplier web portal.	Management / Legal

Appendix A · AI Verification Log

ai-verification-log-project.xlsx

Where AI helped, where it failed, and what we changed

Throughout the investigation, AI was particularly useful in calculating precise time intervals between sequential requests, which allowed us to identify automated patterns such as the fixed 11-second API enumeration and the 17-second configuration rollout across POS machines. Additionally, AI assisted us in crafting highly effective Splunk queries for analyzing file transfers sent from the POS terminals to SRV-STAGE-01 (as detailed in Appendix B, Section 4), allowing us to rapidly quantify the staged log volume and daily write cadences. Beyond technical analysis, AI also helped design a clean, visually appealing slide presentation to effectively communicate our findings. Where AI fell short was in mishandling time zone translations and occasionally missing subtle correlation context between disparate log sources, which required us to manually validate all timestamps, correct query logic, and ground every conclusion directly in raw log evidence.

Appendix B · Queries Used

#	Section	Query
1	4	index=northgate sourcetype=weblog src_ip="77.124.66.19" | table time, src_ip, uri_path, status, bytes_out, method, user_agent | sort time
2	4	index=northgate sourcetype=winevent | where extracted_host="SRV-VEND-APP" | table _time, extracted_host, EventCode, actor, src_host, logon_type, cmdline, target_account, object_name |sort _time
3	4	index=northgate sourcetype=winevent src_host="SRV-VEND-APP" extracted_host="SRV-FILE-HQ" | where EventCode=4672 or EventCode=4624 | sort _time
4	4	index=northgate sourcetype=winevent EventCode=5140 src_host="SRV-VEND-APP" extracted_host="SRV-FILE-HQ" actor="a.mizrahi" | stats count min(_time) as min_time_epoch by object_name | sort min_time_epoch | streamstats current=f window=1 last(min_time_epoch) as prev_time_epoch | eval time_diff_sec = min_time_epoch - prev_time_epoch | eval time_diff = tostring(time_diff_sec, "duration") | eval min_time = strftime(min_time_epoch, "%Y-%m-%d %H:%M:%S") | table object_name count min_time time_diff
5	4	index=northgate sourcetype=winevent EventCode=4624 src_host="SRV-VEND-APP" extracted_host="SRV-POSMGT" actor="r.stern" | lookup assets hostname AS src_host OUTPUT owner AS current_src_owner | lookup assets owner AS actor OUTPUT hostname AS typical_user_hostname | eval is_expected_hostname = if(lower(typical_user_hostname) == lower(src_host), "True", "False") | table _time, actor, typical_user_hostname, src_host, current_src_owner, is_expected_hostname, extracted_host
6	4	index=northgate sourcetype=fileaudit server="SRV-STAGE-01" object_path="*.log.1*" latest="08/18/2026:00:10:01" | stats dc(object_path) as object_path_count sum(bytes_out) as total_bytes_out | eval total_MB_transfered = round(total_bytes_out / 1024 / 1024, 2) | fields object_path_count, total_MB_transfered

7	4	index=northgate sourcetype=winevent EventCode=4688 actor="r.stern" (process="ngpos-cfg.exe" OR process="ngarch.exe") | sort _time | streamstats window=1 current=f last(_time) as prev_time | eval delta_seconds = _time - prev_time | eval time_diff = tostring(abs(delta_seconds), "duration") | eval _time=strftime(_time, "%Y-%m-%d %H:%M:%S") | table _time, extracted_host, process, cmdline, time_diff
8	4	index=northgate sourcetype=fileaudit actor="r.stern" | where src_host!="WKS-PAY-02" and src_host!="SRV-STAGE-01" | stats count, dc(object_path) as distinct_object_path, values(action) as action, sum(bytes_out) as total_bytes, min(time) as min_time, max(time) as max_time by src_host, server | eventstats sum(count) as total_actions_all, sum(total_bytes) as total_bytes_all | eval MB_transferred = round(total_bytes / 1024 / 1024, 2) | eval total_MB_transferred_all = round(total_bytes_all / 1024 / 1024, 2) | sort min_time | where distinct_object_path=count | table src_host, server, count, distinct_object_path, action, MB_transferred, min_time, max_time, total_actions_all, total_MB_transferred_all
9	4	index=northgate sourcetype=proxy src_host="SRV-STAGE-01" | eval MB_out = round(sum(bytes_out/1024/1024),2) | table time, method, MB_out, verdict, dest_host | eventstats sum(MB_out) as total_MB_out | sort time
10	4	index=northgate sourcetype=fileaudit src_host="SRV-STAGE-01" actor="r.stern" action="delete" | stats count as deleted_files, min(_time) as min_time, max(_time) as max_time | eval duration_sec = max_time - min_time | eval duration = tostring(duration_sec, "duration") | eval first_delete = strftime(min_time, "%Y-%m-%d %H:%M:%S"), last_delete = strftime(max_time, "%Y-%m-%d %H:%M:%S") | table deleted_files first_delete last_delete duration

11	4	index=northgate sourcetype=fileaudit actor="r.stern" earliest="08/19/2026:04:30:00" latest="08/19/2026:05:07:38" | where src_host!="WKS-PAY-02" and src_host!="SRV-STAGE-01" | stats count, dc(object_path) as distinct_object_path, values(action) as action, sum(bytes_out) as total_bytes, min(time) as min_time, max(time) as max_time by src_host, server | eventstats sum(count) as total_actions_all, sum(total_bytes) as total_bytes_all | eval MB_transferred = round(total_bytes / 1024 / 1024, 2) | eval total_MB_transferred_all = round(total_bytes_all / 1024 / 1024, 2) | sort min_time | where distinct_object_path=count | table src_host, server, count, distinct_object_path, action, MB_transferred, min_time, max_time, total_actions_all, total_MB_transferred_all
12	4	index=northgate sourcetype=winevent EventCode=5140 actor="a.mizrahi" src_host="SRV-VEND-APP" extracted_host="SRV-FILE-HQ" | eventstats count as total_count_share_folders | stats dc(object_name) as distinct_share_folders values(object_name) as values_share_folders min(_time) as first_seen max(_time) as last_seen | eval first_time_formatted=strftime(first_seen, "%Y-%m-%d %H:%M:%S") | eval last_time_formatted=strftime(last_seen, "%Y-%m-%d %H:%M:%S") | fields - first_seen, last_seen
13	4	index=northgate sourcetype=fileaudit src_host=SRV-VEND-APP | stats count
14	4	index=northgate sourcetype=fileaudit actor="r.stern" | where src_host!="WKS-PAY-02" and src_host!="SRV-STAGE-01" | stats min(_time) as min_time, max(_time) as max_time by src_host, server | sort limit=1 -max_time | eval min_time=strftime(min_time, "%Y-%m-%d %H:%M:%S") | eval max_time=strftime(max_time, "%Y-%m-%d %H:%M:%S")

Appendix C · Evidence Excerpts

#1

time	src_ip	uri_path	status	bytes_out	method	user_agent
2026-08-09 07:12:00	77.124.66.19	/supplier/login	200	1450	POST	Mozilla/5.0 (Macintosh; Intel Mac OS X 14_5) Safari/17.5

#2

_time	extracted_host	EventCode	actor	src_host	logon_type	cmdline	target_account	object_name
2026-08-10 23:04:01.468	SRV-VEND-APP	4688	IIS APPPOOL\supplier			cmd.exe /c "whoami & ipconfig /all & net view" (spawned by w3wp.exe)		
2026-08-10 23:31:01.469	SRV-VEND-APP	4698	IIS APPPOOL\supplier			schtasks /create /tn NGSupplierSync /sc hourly /mo 4	NGSupplierSync	\NGSupplierSync
2026-08-19 04:30:00.469	SRV-VEND-APP	4698	IIS APPPOOL\supplier			schtasks /delete /tn NGSupplierSync /f	NGSupplierSync	\NGSupplierSync

#3

Time	Event
8/11/26 2:15:00.462 AM	2026-08-11 05:15:00,4624,SRV-FILE-HQ,a.mizrahi,3,SRV-VEND-APP,,,, host = DESKTOP-RR49OMB source = northgate_winevent.csv sourcetype = winevent
8/11/26 2:15:01.467 AM	2026-08-11 05:15:01,4672,SRV-FILE-HQ,a.mizrahi,3,SRV-VEND-APP,,,, host = DESKTOP-RR49OMB source = northgate_winevent.csv sourcetype = winevent

#4

object_name	count	min_time	time_diff
\\SRV-FILE-HQ\IT	8	2026-08-12 22:00:00	
\\SRV-FILE-HQ\Payments	8	2026-08-12 22:06:36	00:06:36.0000
\\SRV-FILE-HQ\Finance	7	2026-08-12 22:13:12	00:06:36.0000
\\SRV-FILE-HQ\Vendors	6	2026-08-12 22:19:48	00:06:36.0000
\\SRV-FILE-HQ\Branches	6	2026-08-12 22:26:24	00:06:36.0000
\\SRV-FILE-HQ\Logistics	5	2026-08-12 22:33:00	00:06:36.0000

#5

_time	actor	typical_user_hostname	src_host	current_src_owner	is_expected_hostname	extracted_host
2026-08-15 21:46:59.462	r.stern	SRV-POSMGT SRV-CARDPROC WKS-PAY-02	SRV-VEND-APP	a.mizrahi	False	SRV-POSMGT

#6

object_path_count	total_MB_transfered
1425	214.93

#7

_time	extracted_host	process	cmdline	time_diff
2026-08-16 01:19:59	POS-B01-01	ngpos-cfg.exe	ngpos-cfg.exe /apply /src \\SRV-POSMGT\cfg\pos-profile.dat	
2026-08-16 01:20:16	POS-B02-01	ngpos-cfg.exe	ngpos-cfg.exe /apply /src \\SRV-POSMGT\cfg\pos-profile.dat	00:00:17.0000
2026-08-16 01:20:33	POS-B03-01	ngpos-cfg.exe	ngpos-cfg.exe /apply /src \\SRV-POSMGT\cfg\pos-profile.dat	00:00:17.0000
2026-08-16 01:20:50	POS-B05-01	ngpos-cfg.exe	ngpos-cfg.exe /apply /src \\SRV-POSMGT\cfg\pos-profile.dat	00:00:17.0000
2026-08-16 01:21:07	POS-B06-01	ngpos-cfg.exe	ngpos-cfg.exe /apply /src \\SRV-POSMGT\cfg\pos-profile.dat	00:00:17.0000
2026-08-16 01:21:24	POS-B07-01	ngpos-cfg.exe	ngpos-cfg.exe /apply /src \\SRV-POSMGT\cfg\pos-profile.dat	00:00:17.0000
2026-08-16 01:21:41	POS-B08-01	ngpos-cfg.exe	ngpos-cfg.exe /apply /src \\SRV-POSMGT\cfg\pos-profile.dat	00:00:17.0000
2026-08-19 00:10:01	SRV-STAGE-01	ngarch.exe	ngarch.exe -a -q -o D:\temp\ngsync-0819.dat \\SRV-STAGE-01\temp*.log.1	2+22:40:41.0000

#8

src_host	server	count	distinct_object_path	action	MB_transferred	min_time	max_time	total_actions_all	total_MB_transferred_all
POS-B01-01	SRV-STAGE-01	84	84	write	12.68	2026-08-16 03:00:00	2026-08-19 22:15:50	2850	429.99
POS-B23-01	SRV-STAGE-01	84	84	write	12.67	2026-08-16 03:00:00	2026-08-19 21:52:19	2850	429.99
POS-B02-01	SRV-STAGE-01	84	84	write	12.68	2026-08-16 03:01:41	2026-08-19 22:17:31	2850	429.99
POS-B24-01	SRV-STAGE-01	84	84	write	12.66	2026-08-16 03:01:41	2026-08-19 21:54:00	2850	429.99
POS-B03-01	SRV-STAGE-01	84	84	write	12.69	2026-08-16 03:03:22	2026-08-19 22:19:12	2850	429.99

#9

time	method	MB_out	verdict	dest_host	total_MB_out
2026-08-19 02:55:01	POST	27.38	allowed	edge-sync-eu.net	180.00
2026-08-19 03:10:01	POST	28.43	allowed	edge-sync-eu.net	180.00
2026-08-19 03:25:01	POST	29.48	allowed	edge-sync-eu.net	180.00
2026-08-19 03:40:01	POST	30.52	allowed	edge-sync-eu.net	180.00
2026-08-19 03:55:01	POST	31.57	allowed	edge-sync-eu.net	180.00
2026-08-19 04:10:01	POST	32.62	allowed	edge-sync-eu.net	180.00

#10

deleted_files	first_delete	last_delete	duration
2510	2026-08-19 04:30:00	2026-08-19 05:07:38	00:37:38

#11

src_host	server	count	distinct_object_path	action	MB_transferred	min_time	max_time	total_actions_all	total_MB_transferred_all
POS-B15-01	SRV-STAGE-01	1	1	write	0.15	2026-08-19 04:30:43	2026-08-19 04:30:43	22	3.32
POS-B16-01	SRV-STAGE-01	1	1	write	0.15	2026-08-19 04:32:24	2026-08-19 04:32:24	22	3.32
POS-B17-01	SRV-STAGE-01	1	1	write	0.15	2026-08-19 04:34:05	2026-08-19 04:34:05	22	3.32
POS-B18-01	SRV-STAGE-01	1	1	write	0.15	2026-08-19 04:35:46	2026-08-19 04:35:46	22	3.32
POS-B19-01	SRV-STAGE-01	1	1	write	0.15	2026-08-19 04:37:26	2026-08-19 04:37:26	22	3.32
POS-B20-01	SRV-STAGE-01	1	1	write	0.15	2026-08-19 04:39:07	2026-08-19 04:39:07	22	3.32

#12

distinct_share_folders	values_share_folders	first_time_formatted	last_time_formatted
6	\\SRV-FILE-HQ\Branches \\SRV-FILE-HQ\Finance \\SRV-FILE-HQ\IT \\SRV-FILE-HQ\Logistics \\SRV-FILE-HQ\Payments \\SRV-FILE-HQ\Vendors	2026-08-12 22:00:00	2026-08-15 22:46:12

#13

count
0

#14

src_host	server	min_time	max_time
POS-B14-01	SRV-STAGE-01	2026-08-16 03:18:29	2026-08-19 22:34:19